

20 – Security & several tricks

Keep secure information secret

Jérôme Landré – jerome.landre@ju.se

OUTLINE

- 1) Security
- 2) Several tricks

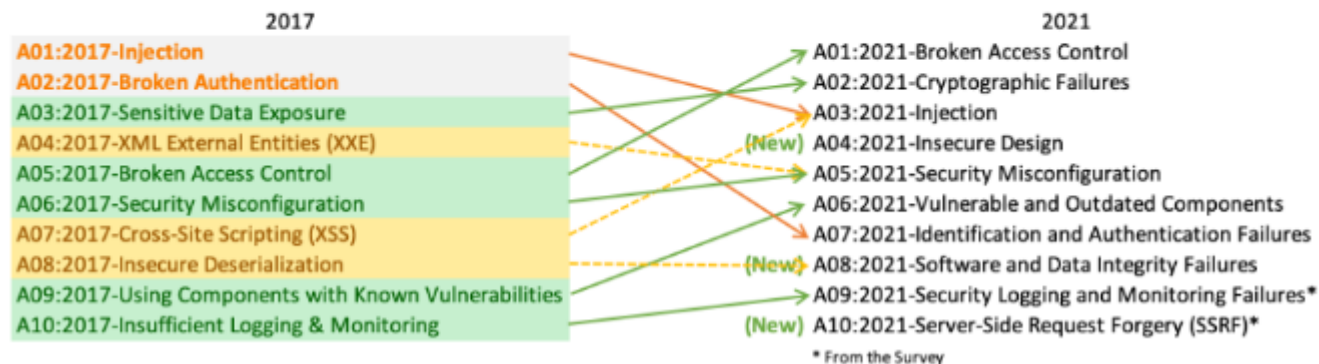
1) SECURITY

- The Open Worldwide Application Security Project (OWASP) defines the top 10 risks for Web Application Security:

<https://owasp.org/www-project-top-ten/>

Top 10 Web Application Security Risks

There are three new categories, four categories with naming and scoping changes, and some consolidation in the Top 10 for 2021.



Source: <https://owasp.org/www-project-top-ten/>

1) A01:2021 – BROKEN ACCESS CONTROL

- --- Access control enforces policy such that users cannot act outside of their intended permissions. ---

https://owasp.org/Top10/A01_2021-Broken_Access_Control/

- In your project: check for every page that need to change content (CUD of the CRUD) that the user has the right to change things!
- In your code: isLoggedIn AND isAdmin; in the routes (session) AND in the handlebar templates (model)

2) A02:2021 – CRYPTOGRAPHIC FAILURES

- --- ... passwords, credit card numbers, health records, personal information, and business secrets require extra protection, ... ---

https://owasp.org/Top10/A02_2021-Cryptographic_Failures/

- In your project: never use a cleartext passwords, USE bcrypt!
- In your code: use `bcrypt.hash(...)` and `bcrypt.compare(...)` to respectively hash a new password or compare a cleartext password and a hash
- Remark: you should also use HTTPS instead of HTTP but this part requires the generation and verification of a certificate, by an external authority of certification

3) A03:2021 – INJECTION

- --- An application is vulnerable to attack when: User-supplied data is not validated, filtered, or sanitized by the application, ... ---

https://owasp.org/Top10/A03_2021-Injection/

- In your project: never use string concatenation in your SQL queries: "SELECT * FROM users WHERE uid="+id : **NO!**
- In your code: use ? For parameters, Node will check if there is an injection of code there. This code is secure: "SELECT * FROM users WHERE uid=?", [id], ...

3) A03:2021 – INJECTION

Search for a project:

(HTML form)

- "SELECT * FROM projects WHERE pid="+id

```
SELECT * FROM projects WHERE id=5
```

- "SELECT * FROM projects WHERE pid=?", [id], ...

```
SELECT * FROM projects WHERE id=5
```

3) A03:2021 – INJECTION

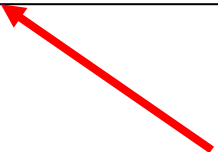
Search for a project: (HTML form)

- "SELECT * FROM projects WHERE pid="+id

```
SELECT * FROM projects WHERE id=5; DELETE FROM users
```

- "SELECT * FROM projects WHERE pid=?", [id], ...

```
SELECT * FROM projects WHERE id=5; DELETE FROM users
```



FORBIDDEN: ERROR!

3) A03:2021 – INJECTION

- Cross-Site Scripting (XSS) is also a security issue
- A hacker can try to send Javascript code in your form fields to try to break your security

User name: (HTML form)

- You should never trust an entry from a form: always check for special characters in it! => SANITIZE your code

<https://www.webmound.com/sanitise-html-nodejs-express-server/>

<https://www.npmjs.com/package/sanitize>

- In your project: do not change anything
- In your code: do not change anything

4) A04:2021 – INSECURE DESIGN

- --- Insecure design is a broad category representing different weaknesses, expressed as “missing or ineffective control design.” ---

https://owasp.org/Top10/A04_2021-Insecure_Design/

- In your project: define clearly the pages that need to be protected against not authorized access and define the roles of the users: admin or not
- In your code: In your code: isLoggedIn AND isAdmin; in the routes (session) AND in the handlebar templates (model) when the page requires special access privileges

5) A05:2021 – SECURITY MISCONFIGURATION

- --- The application might be vulnerable if the application is: Missing appropriate security hardening across any part of the application stack or improperly configured permissions on cloud services... ---
https://owasp.org/Top10/A05_2021-Security_Misconfiguration/
- In your project: define clearly the pages that need to be protected against not authorized access and define the roles of the users: admin or not
- In your code: In your code: isLoggedIn AND isAdmin; in the routes (session) AND in the handlebar templates (model) when the page requires special access privileges

6) A06:2021 – VULNERABLE AND OUTDATED COMPONENTS

- --- You are likely vulnerable: If you do not know the versions of all components you use (both client-side and server-side). This includes components you directly use as well as nested dependencies... ---
https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/
- It means you should update the components you use regularly **HOWEVER** updating Node and npm **the week before** to submit your final project is **DANGEROUS!** If something goes wrong, it is generally difficult to go back to a previous version of your system!
- In your project: don't do any update please
- In your code: do not change anything please

7) A07:2021 – IDENTIFICATION AND AUTHENTICATION FAILURES

- --- Confirmation of the user's identity, authentication, and session management is critical to protect against authentication-related attacks. There may be authentication weaknesses if the application: Permits automated attacks such as credential stuffing, where the attacker has a list of valid usernames and passwords... ---
https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/
- In your project: check the user is the "good" person: check login and username after the login page and put it in the session, you could (not mandatory in your project) also create an automatic login expiration date (3 minutes without any interaction for instance)
- In your code: isLoggedIn AND isAdmin; in the routes (session) AND in the handlebar templates (model) when the page requires special access privileges

8) A08:2021 – SOFTWARE AND DATA INTEGRITY FAILURES

- --- Software and data integrity failures relate to code and infrastructure that does not protect against integrity violations... ---
https://owasp.org/Top10/A08_2021-Software_and_Data_Integrity_Failures/
- If we use plugin libraries or CDNs code that is not ours, we should check the integrity of these online resources
- In your project: check if the versions of the plugins and CDNs you use are the last one
- In your code: Perhaps, do not change anything to your code one week before you submit your final version

9) A09:2021 – SECURITY LOGGING AND MONITORING FAILURES

- --- Without logging and monitoring, breaches cannot be detected. Insufficient logging, detection, monitoring, and active response occurs any time: ... ---
https://owasp.org/Top10/A09_2021-Security_Logging_and_Monitoring_Failures/
- You should have a log database system in which you can save all your console.log(...) debugging messages, for instance, to react to a problem and be able to find why the problem occurred and how to solve it!
- In your project: do not change anything
- In your code: do not change anything

10) A10:2021 – SERVER-SIDE REQUEST FORGERY (SSRF)

- --- SSRF flaws occur whenever a web application is fetching a remote resource without validating the user-supplied URL. It allows an attacker to coerce the application to send a crafted request to an unexpected destination, even when protected by a firewall, VPN, or another type of network access control list (ACL). ---
https://owasp.org/Top10/A10_2021-Server-Side_Request_Forgery_%28SSRF%29/
- --- Enforce “deny by default” firewall policies or network access control rules to block all but essential intranet traffic. ---
- In your project: do not change anything
- In your code: do not change anything

1) SECURITY

- In your project, several security issues can appear but not all of the top 10 risks because we don't use external data (coming from another site) nor cloud services...

1) SECURITY

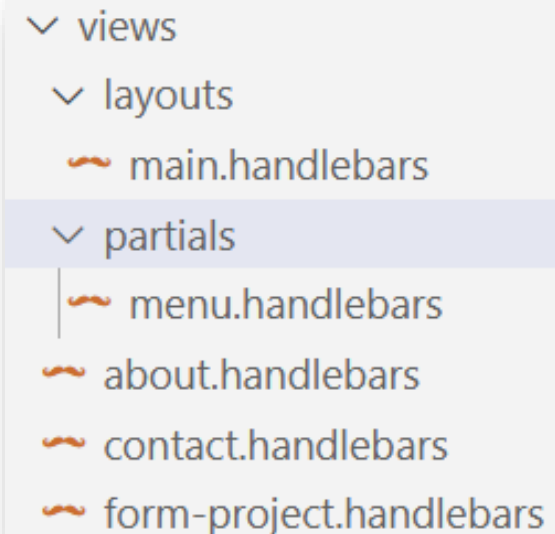
- Security for a website means that you keep the private information “secret”:
 - Use https instead of http on your server:
 - The traffic between the client and the server is encrypted
 - Avoid **SQL injection** by using “?” in your queries (CRUD)
 - Check your users’ **rights**: using isAdmin and isLoggedIn in server.js “if (req.session.isAdmin) { ... }” , as well as in the handlebar files “{{#if session.isAdmin}} ... {{/if}}”
 - Always **escape** character strings using {{theString}} in handlebar files

2) SEVERAL TRICKS

- **Partials:**

- It is a handlebar file that can be used in other handlebar files
- For instance, you can create a menu "partial" in your main.handlebar file:

```
app.engine('handlebars',  
  engine({  
    helpers: {  
      eq (a,b) { return a==b; }  
    }, // define the partials directory  
    partialsDir: __dirname+'/views/'+ 'partials/'  
  })  
)  
// initialize the engine to be handlebars  
app.set('view engine', 'handlebars') // set handlebars as the view engine  
app.set('views', './views') // define the views directory to be ./views
```



```
▼ views  
  ▼ layouts  
    🍷 main.handlebars  
  ▼ partials  
    🍷 menu.handlebars  
    🍷 about.handlebars  
    🍷 contact.handlebars  
    🍷 form-project.handlebars
```

2) SEVERAL TRICKS

- **Partials:**

- It is a handlebar file that can be used in other handlebar files
- For instance, you can create a menu "partial" in your main.handlebar file:

```
<!DOCTYPE html>
<html lang="en">
  <head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-
    <title>JL portfolio</title>
    <link rel="stylesheet" href="/css/jl-styles.css">
  </head>
  <body>
    {{> menu}}
    {{{body}}}
    <footer>
      &copy; JL - 2025
    </footer>
  </body>
</html>
```

views > partials > menu.handlebars > ...

```
1
2   <header>
3     <div>
4       <a href="/">Home</a>
5       <a href="/projects">Projects</a>
6       <a href="/skills">Skills</a>
7       <a href="/about">About</a>
8       <a href="/contact">Contact</a>
9       <span class="emptyspace"> </span>
10      {{#if session.isLoggedIn}}
11        Hej, {{session.un}}!
12        <a href="/logout">Logout</a>
13      {{else}}
14        <a href="/login">Login</a>
15      {{/if}}
16    </div>
17  </header>
```

2) SEVERAL TRICKS

- Partial:
 - They are useful because you can define different menus in different parts of your website using conditions:

```
{{#if session.isLoggedIn}}  
    {{> menu2}}  
{{else}}  
    {{> menu}}  
{{/if}}
```

[Home](#) [Projects](#) [Skills](#) [About](#) [Contact](#) [Login](#)

Welcome!

You are visiting my personal portfolio, cool!

2) SEVERAL TRICKS

- **Routers**: for your project, you could have created a router to deal with your two routes `"/projects"` and `"/skills"`:

```
project-folder/  
├─ app.js  
├─ routes/  
│   ├─ projects.js  
│   └─ skills.js  
├─ views/  
│   ├─ projects.hbs  
│   └─ skills.hbs  
├─ db/  
│   └─ database.db  
└─ package.json
```

Source: GPT-5

```
const express = require('express');  
const exphbs = require('express-handlebars');  
const sqlite3 = require('sqlite3').verbose();  
  
const projectsRouter = require('./routes/projects');  
const skillsRouter = require('./routes/skills');  
  
const app = express();  
  
// Set up Handlebars  
app.engine('hbs', exphbs.engine({ extname: '.hbs' }));  
app.set('view engine', 'hbs');  
  
// Database connection  
const db = new sqlite3.Database('./db/database.db', (err) => {  
  if (err) {  
    console.error('Database connection error:', err.message);  
  } else {  
    console.log('Connected to SQLite database.');  }  
});  
  
// Pass db to routers via middleware  
app.use((req, res, next) => {  
  req.db = db;  
  next();  
});  
  
// Routers  
app.use('/projects', projectsRouter);  
app.use('/skills', skillsRouter);  
  
// Server start  
app.listen(3000, () => {  
  console.log('Server running on http://localhost:3000');});
```

2) SEVERAL TRICKS

routes/projects.js

js



```
const express = require('express');
const router = express.Router();

router.get('/', (req, res) => {
  req.db.all('SELECT * FROM projects', [], (err, rows) => {
    if (err) {
      console.error(err.message);
      return res.status(500).send('Database error');
    }
    res.render('projects', { projects: rows });
  });
});

module.exports = router;
```

2) SEVERAL TRICKS

routes/skills.js

js



```
const express = require('express');
const router = express.Router();

router.get('/', (req, res) => {
  req.db.all('SELECT * FROM skills', [], (err, rows) => {
    if (err) {
      console.error(err.message);
      return res.status(500).send('Database error');
    }
    res.render('skills', { skills: rows });
  });
});

module.exports = router;
```


2) SEVERAL TRICKS

views/projects.hbs

hbs



```
<h1>Projects</h1>
<ul>
  {{#each projects}}
    <li>{{this.name}} - {{this.description}}</li>
  {{/each}}
</ul>
```

views/skills.hbs

hbs



```
<h1>Skills</h1>
<ul>
  {{#each skills}}
    <li>{{this.skill_name}} (Level: {{this.level}})</li>
  {{/each}}
</ul>
```

2) SEVERAL TRICKS

- SQLite3: Because Javascript is **asynchronous**, the order of operations in your DB are not necessarily the one written in the code!
- To ensure several queries to be run in the correct order, you can use the **serialize** function:

```
const db = new sqlite3.Database('university.db');

// Create the universities table
db.serialize(() => {
  db.run('DROP TABLE IF EXISTS universities');
  db.run('CREATE TABLE universities (university_id INTEGER PRIMARY KEY, university_name TEXT)');
  db.run('INSERT INTO universities (university_name) VALUES ("Harvard University")');
});
```

2) SEVERAL TRICKS

- We could have added the status of the response when we send it to the client:

```
//-----  
//--- DEFINE THE ROUTES AND METHODS  
//-----  
app.get('/', (request, response) => {  
  console.log('---> SESSION INFORMATION: ', JSON.stringify(request.session))  
  response.status(200).render('home') // the landing page information  
})  
app.get('/contact', (request, response) => {  
  response.status(200).render('contact') // the contact information  
})
```

Code	Category	Meaning
100	Informational	Continue
101	Informational	Switching Protocols
200	Success	OK
201	Success	Created
202	Success	Accepted
204	Success	No Content
301	Redirection	Moved Permanently
302	Redirection	Found (Temporary Redirect)
304	Redirection	Not Modified
307	Redirection	Temporary Redirect (preserve method)
400	Client Error	Bad Request
401	Client Error	Unauthorized
403	Client Error	Forbidden
404	Client Error	Not Found
405	Client Error	Method Not Allowed
429	Client Error	Too Many Requests
500	Server Error	Internal Server Error
502	Server Error	Bad Gateway
503	Server Error	Service Unavailable
504	Server Error	Gateway Timeout

2) SEVERAL TRICKS

- We could have added the status of the response when we send it to the client:

```
app.get('/projects', (request, response) => {
  db.all('SELECT * FROM projects', (err, theProjects) => {
    if (err) {
      console.error(err.message);
      const model = { error: "Error retrieving projects from the database." }
      response.status(400).render('projects', model);
    } else {
      console.log(`---> Retrieved ${theProjects.length} projects from the database.`);
      console.log(`---> Projects: ${JSON.stringify(theProjects)}`);
      const model = { projects: theProjects };
      response.status(200).render('projects', model); // the list of projects
    }
  });
});
```

Code	Category	Meaning
100	Informational	Continue
101	Informational	Switching Protocols
200	Success	OK
201	Success	Created
202	Success	Accepted
204	Success	No Content
301	Redirection	Moved Permanently
302	Redirection	Found (Temporary Redirect)
304	Redirection	Not Modified
307	Redirection	Temporary Redirect (preserve method)
400	Client Error	Bad Request
401	Client Error	Unauthorized
403	Client Error	Forbidden
404	Client Error	Not Found
405	Client Error	Method Not Allowed
429	Client Error	Too Many Requests
500	Server Error	Internal Server Error
502	Server Error	Bad Gateway
503	Server Error	Service Unavailable
504	Server Error	Gateway Timeout

2) SEVERAL TRICKS

jerome

All Bookmarks

Home Projects Skills About Contact Login

List of Projects

Counting 345 people with a camera

The 456 purpose of this project is to count people passing through a corridor and to know how many are in the room at a certain time. Year: 2025.

Visualisation 2 of 3D medical images

The project makes a 3D model of the analysis of the body of a person and displays the detected health problems. It is useful for doctors to view in 3D their patients and the evolution of a disease. Year: 2020.

Multiple questions system

During the lockdowns in France, this project was useful to test the students online with a Quizz system. Year: 2021.

Image comparison with the Local Dissimilarity Map

The project is about finding and quantifying the differences between two images of the same size. The applications were numerous: satellite imaging, medical imaging,... Year: 2020.

Management system for students' internships

This project was about the creation of a database to manage the students' internships. Year: 2012.

Signal 2 Analysis for Detection of Epileptic Diseases

This project 3 was about the detection of epileptic problems in signals. Year: 2020.

jerome

why Year: 2025.

Year: .

© JL - 2025

Elements Recorder Console Sources Network Performance Memory Application

Preserve log

Disable cache

No throttling

Filter

Invert

More filters

All

Fetch/XHR

Doc

CSS

JS

Font

Img

Media

Manifest

Socket

Wasm

Other

50 ms

100 ms

150 ms

200 ms

250 ms

300 ms

350 ms

400 ms

Name

Status

Type

Initiator

Size

Ti...

projects

200

document

Other

3.0 kB

1...

jl-styles.css

200

stylesheet

projects:7

0.6 kB

1...

content.css

200

fetch

content.js:2

1,161 kB

4 ...

Code	Category	Meaning
100	Informational	Continue
101	Informational	Switching Protocols
200	Success	OK
201	Success	Created
202	Success	Accepted
204	Success	No Content
301	Redirection	Moved Permanently
302	Redirection	Found (Temporary Redirect)
304	Redirection	Not Modified
307	Redirection	Temporary Redirect (preserve method)
400	Client Error	Bad Request
401	Client Error	Unauthorized
403	Client Error	Forbidden
404	Client Error	Not Found
405	Client Error	Method Not Allowed
429	Client Error	Too Many Requests
500	Server Error	Internal Server Error
502	Server Error	Bad Gateway
503	Server Error	Service Unavailable
504	Server Error	Gateway Timeout

ANY QUESTIONS?